CYTECH ACADEMY

Ethical Hacking & Penetration Testing

Complete Study Notes - beginner friendly, exam and lab ready.

(c) CyTech. For enrolled students. Unauthorized attack is illegal - practice only in labs.

Table of Contents

1. Rules of Engagement

2. Phase 1 - Reconnaissance

3. Phase 2 - Scanning & Enumeration

4. Phase 3 - Exploitation

5. Phase 4 - Post-Exploitation & Reporting

Rules of Engagement

Ethical hacking is authorized testing. Never touch a system without written permission defining scope, timing and allowed techniques. A signed rules-of-engagement contract protects you legally.

Practice legally on: testphp.vulnweb.com (Acunetix test site), DVWA, Metasploitable 2/3, OWASP Juice Shop, HackTheBox, TryHackMe, VulnHub VMs.

Phase 1 - Reconnaissance

Passive OSINT: WHOIS, DNS records (dig, nslookup), Google dorking (site:, filetype:, inurl:), Shodan, certificate transparency logs (crt.sh), LinkedIn for staff names, theHarvester for emails.

Active: host discovery and port scanning with Nmap. Examples: nmap -sn 192.168.1.0/24 (ping sweep), nmap -sV -sC -O target (services, default scripts, OS), nmap -p- --min-rate 5000 target (all ports).

Phase 2 - Scanning & Enumeration

Enumerate services: SMB (enum4linux, smbclient), web directories (gobuster, ffuf, dirb), DNS zone transfer (dig axfr), SNMP. Nikto and OWASP ZAP find known web weaknesses automatically.

Map every input: URL parameters, forms, cookies, headers, file uploads. Inputs are where vulnerabilities live.

Phase 3 - Exploitation

SQL injection: test with a single quote; confirm with ' OR '1'='1; automate with sqlmap -u 'URL?id=1' --dbs. XSS: inject alert(1); stored XSS is most dangerous. Command injection: append ;id or |whoami.

Metasploit workflow: msfconsole; search ; use exploit/...; set RHOSTS/LHOST; run. Always prefer the least-destructive proof of concept that demonstrates impact.

Phase 4 - Post-Exploitation & Reporting

After access: establish persistence conceptually, escalate privileges (linpeas/winpeas, sudo -l, unquoted service paths), pivot, and - most importantly - collect evidence (screenshots, timestamps).

The report is the product: executive summary, findings with CVSS severity, business impact, reproduction steps, and concrete remediation. A great pentester is 50% writer.